

SOC 2 Type 2 Report

Document ID	Version	Owner	Effective Date	Framework	Classification
SOC2-RPT-[YYYY]-[NN]	1.0	[Compliance Owner / GRC Lead]	[Effective Date]	SOC 2 Type 2	Confidential - Restricted Distribution

Purpose

This SOC 2 Type 2 Report documents the operating effectiveness of controls supporting the security, availability, processing integrity, confidentiality, and privacy commitments of [Organisation Name] over the defined reporting period.

The report is intended to provide management, customers, auditors, and other authorised stakeholders with a clear and evidence-based assessment of whether relevant controls were suitably designed and operated consistently throughout the period. It also records exceptions, management responses, remediation activity, and recommendations for strengthening the control environment.

This document is prepared for the following purposes:

- To summarise the operating effectiveness of controls relevant to [Organisation Name]’s in-scope services.
- To support customer assurance, vendor due diligence, and contractual assurance obligations.
- To provide management with a consolidated view of control performance and residual risk.
- To document exceptions, corrective actions, and accountability for remediation.
- To support continuous improvement of the trust and assurance programme.

This report is not a substitute for the independent service auditor’s report issued by [Audit Firm], where applicable. It is an internal management report designed to support readiness, oversight, remediation, and stakeholder communication.

Reporting Period & Scope

Reporting Period

Attribute	Detail
Reporting Period Start	[Start Date]
Reporting Period End	[End Date]
Review Type	SOC 2 Type 2 operating effectiveness review
Evidence Review Window	Evidence collected and reviewed for activities occurring during the reporting period
Report Preparation Date	[Report Date]
Prepared By	[Name / Role / Function]
Reviewed By	[Name / Role / Function]
Approved By	[Name / Role / Function]

In-Scope Services

This report covers the services, systems, processes, and control activities that support the delivery of [Organisation Name]’s [in-scope product/service/platform].

In-Scope Area	Description
Service / Product	[Name of SaaS platform, managed service, application, infrastructure service, or business service]
Primary Users	[Customers, internal users, external partners, administrators]
Service Locations	[Cloud region(s), office location(s), data centre(s), remote workforce locations]
Hosting Model	[Cloud-hosted / hybrid / on-premises / managed hosting]
Cloud / Infrastructure Provider(s)	[Provider names]
Key Business Processes	Customer onboarding, user access management, change management, incident management, monitoring, backup and recovery, vendor management, risk management, security governance
Data Types Processed	[Customer data, personal data, confidential business data, authentication data, logs, support data]
Primary Control Owners	Engineering, Security, IT Operations, Compliance, People Operations, Legal, Customer Support, Product Management

In-Scope Trust Service Areas

The assessment considered controls relevant to the following trust service areas:

Area	Included	Description
Security	Yes	Protection against unauthorised access, unauthorised disclosure, system abuse, and security events
Availability	[Yes/No]	System availability commitments, resilience, monitoring, backup, recovery, and capacity management
Processing Integrity	[Yes/No]	Completeness, accuracy, validity, timeliness, and authorisation of system processing
Confidentiality	[Yes/No]	Protection of confidential information throughout its lifecycle
Privacy	[Yes/No]	Collection, use, retention, disclosure, and disposal of personal information in line with privacy commitments

In-Scope Systems and Tools

System / Tool	Purpose	Control Relevance	Owner
[Identity Provider]	Authentication, single sign-on, multi-factor authentication	Access control and user lifecycle management	[Owner]
[Cloud Platform]	Hosting and infrastructure services	Infrastructure security, logging, monitoring, resilience	[Owner]
[Source Code Repository]	Source code management and peer review	Change management and secure development	[Owner]
[CI/CD Platform]	Build, test, and deployment automation	Change deployment and release control	[Owner]
[Ticketing System]	Change, incident, request, and access workflow management	Workflow evidence and approval tracking	[Owner]
[Endpoint Management Tool]	Device configuration, patching, and security posture	Endpoint protection and asset management	[Owner]
[Security Monitoring Platform]	Alerting, event monitoring, threat detection	Security operations and incident response	[Owner]
[HRIS]	Employee onboarding, role changes, and offboarding	Personnel lifecycle and access triggers	[Owner]
[Vendor Management Tool / Repository]	Third-party review and contract tracking	Supplier risk management	[Owner]

Out-of-Scope Areas

The following areas were not assessed as part of this report:

Out-of-Scope Area	Rationale
[System / process]	[Reason, e.g., not used to deliver the in-scope service]
[Legacy environment]	[Reason, e.g., decommissioned before reporting period]
[Customer-managed configurations]	Controls are the responsibility of customers under the shared responsibility model
[Non-production sandbox environments]	Excluded unless connected to production data or production access pathways

Significant Changes During the Period

Change	Date / Period	Impact on Scope or Controls	Management Assessment
[Cloud migration / architecture change]	[Date]	[Impact]	[Assessment]
[New identity provider implementation]	[Date]	[Impact]	[Assessment]
[Major product release]	[Date]	[Impact]	[Assessment]
[Organisational restructuring]	[Date]	[Impact]	[Assessment]
[New subprocessors / vendors]	[Date]	[Impact]	[Assessment]

Executive Summary

Overall Conclusion

Based on the assessment performed for the reporting period [Start Date] to [End Date], the control environment supporting [Organisation Name]'s in-scope service was generally effective in meeting its stated service commitments and system requirements.

Controls were operating as intended in most areas, with evidence showing consistent execution across access management, change management, security monitoring, incident response, personnel security, vendor oversight, and governance processes.

The review identified the following overall result:

Result Area	Summary
Overall Control Effectiveness	[Effective / Effective with exceptions / Not effective]
Number of Control Areas Reviewed	[Number]
Number of Controls Tested	[Number]
Controls Operating Effectively	[Number]
Controls with Exceptions	[Number]
Significant Exceptions	[Number]
Open Corrective Actions at Report Date	[Number]
High-Risk Issues	[Number]
Management Readiness for External Audit	[Ready / Ready with remediation / Not ready]

Summary of Key Strengths

The following strengths were observed during the assessment:

- Strong use of centralised identity management, including multi-factor authentication for privileged and remote access.
- Evidence of role-based access provisioning supported by documented approval workflows.
- Formalised change management process with code review, testing, approval, and deployment evidence.

- Security monitoring and alert triage processes operating with defined ownership and escalation paths.
- Incident response procedures supported by documented investigation and communication workflows.
- Employee onboarding and offboarding processes linked to access provisioning and removal activities.
- Vendor risk management processes in place for key service providers and subprocessors.
- Regular management review of security risks, audit readiness, and remediation progress.
- Backup, recovery, and availability monitoring controls in place for critical services.
- Policies and procedures maintained for information security, access control, acceptable use, incident response, vendor management, and business continuity.

Summary of Exceptions

The review identified the following exceptions requiring management attention:

Finding ID	Area	Severity	Summary	Status
SOC2-F-[001]	Access Management	[Low/Medium/High]	[Example: Quarterly access review was completed after the required due date for one system.]	[Open/In Progress/Closed]
SOC2-F-[002]	Change Management	[Low/Medium/High]	[Example: One production change lacked evidence of documented pre-deployment approval.]	[Open/In Progress/Closed]
SOC2-F-[003]	Vendor Management	[Low/Medium/High]	[Example: Annual vendor reassessment evidence was incomplete for one medium-risk vendor.]	[Open/In Progress/Closed]
SOC2-F-[004]	Asset Management	[Low/Medium/High]	[Example: Asset inventory record was missing assigned owner for a subset of endpoints.]	[Open/In Progress/Closed]

Management Statement

Management acknowledges responsibility for the design, implementation, and operation of controls supporting the in-scope service. Management has reviewed the results of this report and agrees with the findings, risk ratings, and remediation actions described herein.

Management is committed to addressing identified exceptions within the agreed timelines and to maintaining a control environment that supports customer trust, operational resilience, information security, and compliance obligations.

Methodology

Assessment Approach

The assessment evaluated whether selected controls operated effectively throughout the reporting period. Testing was performed using a combination of inquiry, inspection, observation, reperformance, and evidence analysis.

The assessment focused on whether:

- Control activities were performed by authorised and competent personnel.
- Control execution was supported by complete and reliable evidence.

- Controls operated at the required frequency.
- Exceptions were identified, escalated, and remediated in a timely manner.
- Control outcomes aligned with documented policies, procedures, service commitments, and customer obligations.
- Changes to systems, people, vendors, and processes were appropriately reflected in the control environment.

Evidence Sources

Evidence was obtained from the following sources:

Evidence Source	Examples Reviewed
Policies and Procedures	Information security policy, access control procedure, incident response plan, change management procedure, vendor management procedure
System Exports	User access listings, role assignments, administrator listings, configuration exports, monitoring reports
Tickets and Workflow Records	Access requests, change tickets, incident records, support tickets, vendor review records
Logs and Reports	Authentication logs, deployment logs, vulnerability scan results, backup job reports, alert logs
Meeting Records	Security committee minutes, risk review records, management review notes, post-incident reviews
HR Records	Employee start dates, termination records, role change records, background check evidence, training completion records
Vendor Records	Due diligence reviews, contracts, security questionnaires, assurance reports, data processing agreements
Technical Evidence	Screenshots, configuration settings, code review history, pull request approvals, encryption settings

Testing Techniques

Technique	Description	Example Application
Inquiry	Discussion with control owners and process participants	Confirming incident escalation practice with Security Operations
Inspection	Review of documented evidence	Reviewing access approval tickets and termination records
Observation	Viewing a process or configuration directly	Observing multi-factor authentication enforcement settings
Reperformance	Independently repeating part of a control activity	Verifying whether sampled users had appropriate access based on role
Data Analysis	Reviewing populations, samples, and exceptions	Comparing terminated employees to active user listings

Sampling Approach

Sampling was performed using a risk-based method. Sample sizes were determined based on control frequency, population size, control risk, prior exceptions, degree of automation, and significance to customer commitments.

Control Frequency	Typical Sample Approach
Continuous / Automated	Configuration inspection, system export review, and monitoring of change history
Daily	Sample across multiple months, including high-volume and low-volume periods
Weekly	Sample from each quarter or representative months
Monthly	Sample selected months across the reporting period
Quarterly	Review all occurrences where feasible
Annual	Review the single annual occurrence and related approval evidence

Control Frequency	Typical Sample Approach
Event-Based	Sample from the full population of events during the period

Severity Rating Method

Findings were rated based on likelihood, impact, duration, control dependency, customer effect, compensating controls, and whether the issue represented an isolated exception or a systemic weakness.

Severity	Definition	Expected Management Response
High	A significant control failure that may materially affect service commitments, customer data protection, or operational resilience	Immediate remediation plan, executive visibility, root cause analysis, and close tracking
Medium	A control weakness or repeated exception that could affect control reliability if not remediated	Corrective action required within an agreed timeframe with owner accountability
Low	An isolated or low-impact exception that does not materially affect the control objective	Remediation or process improvement recommended
Observation	Improvement opportunity where no control failure was identified	Management to consider enhancement based on risk and practicality

Limitations

This report is based on evidence available at the time of review. It does not provide assurance over areas outside the stated scope or periods outside the reporting window. Where evidence was unavailable, incomplete, or obtained after the fact, this is noted in the relevant finding.

The effectiveness of controls may be affected by changes in personnel, systems, vendors, threat conditions, or business processes after the reporting period.

Detailed Findings / Results (with structure)

Results Overview

Control Area	Controls Tested	Effective	Exceptions	Overall Result
Governance and Risk Management	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Security Policies and Awareness	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Logical Access Management	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Privileged Access Management	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Change Management	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Secure Development	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Security Monitoring and Incident Response	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Vulnerability and Patch Management	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Availability, Backup, and Recovery	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Vendor and Subprocessor Management	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Confidentiality and Data Protection	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Privacy Operations	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]

Control Area	Controls Tested	Effective	Exceptions	Overall Result
Human Resources and Personnel Security	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]
Business Continuity and Resilience	[Number]	[Number]	[Number]	[Effective / Effective with exceptions / Not effective]

1. Governance and Risk Management

Control Expectations

Management is expected to maintain an effective governance structure for information security, risk management, compliance oversight, and accountability. This includes defined roles, periodic risk assessments, management review, documented policies, and oversight of remediation activities.

Procedures Performed

- Reviewed information security governance structure and ownership assignments.
- Inspected management meeting records and risk review outputs.
- Reviewed risk register entries and treatment decisions.
- Verified that policy exceptions and control issues were tracked.
- Confirmed that management reviewed audit readiness and remediation status.

Results

Test Area	Result	Evidence Reviewed
Governance roles and responsibilities defined	[Pass/Exception]	[Role matrix, organisation chart, committee charter]
Risk assessment completed during reporting period	[Pass/Exception]	[Risk register, risk assessment report]
Management reviews performed	[Pass/Exception]	[Meeting minutes, dashboards, action logs]
Remediation actions tracked	[Pass/Exception]	[Issue tracker, risk treatment plans]

Finding

Field	Detail
Finding ID	SOC2-F-[001]
Severity	[Low/Medium/High/Observation]
Condition	[Describe what was found.]
Criteria	Governance processes should provide timely oversight of risks, controls, and remediation activity.
Cause	[Root cause or contributing factor.]
Effect / Risk	[Potential impact on control oversight, customer commitments, or timely remediation.]
Evidence	[Evidence reference.]
Management Response	[Management response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Open/In Progress/Closed]

2. Security Policies and Awareness

Control Expectations

Security policies and supporting procedures should be approved, communicated, reviewed periodically, and made available to personnel. Employees and contractors should complete security awareness training appropriate to their roles.

Procedures Performed

- Reviewed policy approval and publication evidence.
- Inspected records of annual policy review.
- Tested security awareness training completion.
- Reviewed role-specific training evidence for personnel with elevated responsibilities.
- Confirmed that new hires completed required training within expected timelines.

Results

Test Area	Result	Evidence Reviewed
Security policies approved and current	[Pass/Exception]	[Policy repository, approval records]
Policies communicated to personnel	[Pass/Exception]	[Employee acknowledgement records]
Security awareness training completed	[Pass/Exception]	[Training completion report]
New hire training completed timely	[Pass/Exception]	[HRIS records, LMS report]

Finding

Field	Detail
Finding ID	SOC2-F-[002]
Severity	[Low/Medium/High/Observation]
Condition	[Describe any exception or state "No exception noted".]
Criteria	Personnel should be informed of security responsibilities and complete required training within defined timeframes.
Cause	[Root cause or "Not applicable".]
Effect / Risk	[Potential impact.]
Evidence	[Evidence reference.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Open/In Progress/Closed/Not Applicable]

3. Logical Access Management

Control Expectations

Access to in-scope systems should be authorised, appropriate to job responsibilities, reviewed periodically, and removed promptly when no longer required.

Procedures Performed

- Tested a sample of new user access requests for documented approval.
- Compared active user listings to current personnel records.
- Reviewed terminated employee access removal evidence.
- Tested periodic access review completion and follow-up.
- Reviewed access for shared, service, and emergency accounts.
- Confirmed multi-factor authentication requirements for applicable systems.

Results

Test Area	Result	Evidence Reviewed
New user access approved before provisioning	[Pass/Exception]	[Access tickets, approval records]
Access aligned to job role	[Pass/Exception]	[Role matrix, user listings]
Terminated user access removed timely	[Pass/Exception]	[HR termination report, system logs]
Periodic access reviews completed	[Pass/Exception]	[Review attestations, remediation evidence]
Multi-factor authentication enforced	[Pass/Exception]	[Identity provider configuration]

Finding

Field	Detail
Finding ID	SOC2-F-[003]
Severity	[Low/Medium/High/Observation]
Condition	[Example: One of [sample size] sampled access requests did not contain documented approval prior to provisioning.]
Criteria	User access should be approved before provisioning and reviewed periodically for continued business need.
Cause	[Example: Access was granted through an urgent manual request outside the standard workflow.]
Effect / Risk	[Example: Unapproved access may increase the risk of unauthorised system activity.]
Evidence	[Access ticket ID, system export, review record]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Open/In Progress/Closed]

4. Privileged Access Management

Control Expectations

Administrative and privileged access should be restricted, approved, logged, monitored, reviewed, and limited to personnel with a valid business need.

Procedures Performed

- Reviewed administrator listings for in-scope systems.
- Tested approval evidence for privileged access grants.

- Confirmed use of multi-factor authentication for privileged accounts.
- Inspected privileged access review records.
- Reviewed monitoring and logging for administrative activity.
- Evaluated use of shared administrator accounts and emergency access.

Results

Test Area	Result	Evidence Reviewed
Privileged access approved	[Pass/Exception]	[Admin access tickets]
Privileged access limited to authorised personnel	[Pass/Exception]	[Admin group export, HR records]
Privileged access reviewed periodically	[Pass/Exception]	[Review records]
Administrative activity logged	[Pass/Exception]	[Audit logs, monitoring platform]
Emergency access controlled	[Pass/Exception]	[Break-glass procedure, account logs]

Finding

Field	Detail
Finding ID	SOC2-F-[004]
Severity	[Low/Medium/High/Observation]
Condition	[Describe result.]
Criteria	Privileged access should be tightly controlled and reviewed due to its elevated risk.
Cause	[Cause.]
Effect / Risk	[Risk.]
Evidence	[Evidence.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Status]

5. Change Management

Control Expectations

Changes to production systems should be authorised, tested, reviewed, approved, and traceable. Emergency changes should be documented and reviewed after implementation.

Procedures Performed

- Selected a sample of production changes during the reporting period.
- Reviewed change tickets for approval, testing, and implementation evidence.
- Inspected pull requests for peer review and merge approval.
- Verified segregation between development and production deployment responsibilities where applicable.
- Reviewed emergency changes and post-implementation review evidence.
- Confirmed rollback or recovery planning for significant changes.

Results

Test Area	Result	Evidence Reviewed
Production changes documented	[Pass/Exception]	[Change tickets, release notes]
Changes approved before deployment	[Pass/Exception]	[Approvals, pull request records]
Testing completed before deployment	[Pass/Exception]	[Test evidence, CI/CD output]
Code peer reviewed	[Pass/Exception]	[Repository records]
Emergency changes reviewed after implementation	[Pass/Exception]	[Emergency change tickets]

Finding

Field	Detail
Finding ID	SOC2-F-[005]
Severity	[Low/Medium/High/Observation]
Condition	[Example: One production change lacked evidence of documented pre-deployment approval.]
Criteria	Production changes should be approved, tested, and traceable before implementation unless handled under an emergency process.
Cause	[Example: Change was deployed during a production issue and not retrospectively updated.]
Effect / Risk	[Example: Inadequate change documentation may impair traceability and increase the risk of unauthorised or unstable changes.]
Evidence	[Change ticket, deployment log, pull request link]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Open/In Progress/Closed]

6. Secure Development

Control Expectations

Software development should include secure design, code review, vulnerability detection, controlled deployment, and protection of secrets and credentials.

Procedures Performed

- Reviewed secure development procedures and coding guidance.
- Inspected code review requirements and pull request evidence.
- Reviewed static analysis, dependency scanning, and container scanning outputs where applicable.
- Evaluated remediation tracking for identified vulnerabilities.
- Reviewed access controls for source code repositories.
- Confirmed secrets management practices for production credentials.

Results

Test Area	Result	Evidence Reviewed
Secure development guidance maintained	[Pass/Exception]	[Engineering standards, secure coding guide]
Code changes peer reviewed	[Pass/Exception]	[Pull requests]
Vulnerability scanning integrated	[Pass/Exception]	[Scan results, CI/CD records]
Critical findings remediated timely	[Pass/Exception]	[Issue tracker, scan history]
Secrets protected from code exposure	[Pass/Exception]	[Secrets scanning results, vault configuration]

Finding

Field	Detail
Finding ID	SOC2-F-[006]
Severity	[Low/Medium/High/Observation]
Condition	[Describe result.]
Criteria	Development practices should reduce the likelihood of introducing security weaknesses into production systems.
Cause	[Cause.]
Effect / Risk	[Risk.]
Evidence	[Evidence.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Status]

7. Security Monitoring and Incident Response

Control Expectations

Security events should be logged, monitored, triaged, escalated, investigated, and resolved in accordance with documented incident response procedures.

Procedures Performed

- Reviewed logging and monitoring coverage for in-scope systems.
- Inspected alert triage records and escalation evidence.
- Tested a sample of security events and incidents.
- Reviewed incident response procedures and contact lists.
- Confirmed post-incident review activity for qualifying incidents.
- Reviewed evidence of incident communication decision-making.

Results

Test Area	Result	Evidence Reviewed
Security logging enabled for critical systems	[Pass/Exception]	[Logging configuration, SIEM dashboards]
Alerts triaged timely	[Pass/Exception]	[Alert tickets, timestamps]
Incidents documented and classified	[Pass/Exception]	[Incident records]
Escalation procedures followed	[Pass/Exception]	[Incident timeline, communication logs]

Test Area	Result	Evidence Reviewed
Post-incident reviews completed where required	[Pass/Exception]	[Post-incident reports]

Finding

Field	Detail
Finding ID	SOC2-F-[007]
Severity	[Low/Medium/High/Observation]
Condition	[Describe result.]
Criteria	Security events and incidents should be handled consistently, with timely investigation and documented resolution.
Cause	[Cause.]
Effect / Risk	[Risk.]
Evidence	[Evidence.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Status]

8. Vulnerability and Patch Management

Control Expectations

Systems should be assessed for vulnerabilities, prioritised based on risk, and remediated within defined timeframes. Patch management should be tracked and monitored for critical infrastructure, endpoints, applications, and dependencies.

Procedures Performed

- Reviewed vulnerability scanning coverage and frequency.
- Inspected vulnerability reports and remediation tickets.
- Tested a sample of critical and high-risk vulnerabilities for timely remediation.
- Reviewed patch status for endpoints and servers.
- Confirmed exception handling for deferred remediation.
- Reviewed dependency and container vulnerability management where applicable.

Results

Test Area	Result	Evidence Reviewed
Vulnerability scans performed	[Pass/Exception]	[Scan reports]
Critical vulnerabilities tracked	[Pass/Exception]	[Remediation tickets]
Remediation completed within target timelines	[Pass/Exception]	[Ticket closure evidence, rescan results]
Patch compliance monitored	[Pass/Exception]	[Patch dashboard]
Exceptions approved and documented	[Pass/Exception]	[Risk acceptance records]

Finding

Field	Detail
Finding ID	SOC2-F-[008]
Severity	[Low/Medium/High/Observation]
Condition	[Describe result.]
Criteria	Vulnerabilities should be identified and remediated in a timely manner based on risk.
Cause	[Cause.]
Effect / Risk	[Risk.]
Evidence	[Evidence.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Status]

9. Availability, Backup, and Recovery

Control Expectations

The service should be monitored for availability, supported by backup and recovery processes, and protected through resilience measures aligned to business commitments.

Procedures Performed

- Reviewed uptime monitoring reports and service dashboards.
- Inspected backup configuration and backup completion records.
- Reviewed restoration test evidence.
- Confirmed incident and outage tracking.
- Reviewed capacity monitoring and alerting.
- Evaluated business continuity and disaster recovery testing evidence.

Results

Test Area	Result	Evidence Reviewed
Availability monitoring operating	[Pass/Exception]	[Monitoring dashboards, alert records]
Backup jobs completed successfully	[Pass/Exception]	[Backup logs]
Backup failures investigated	[Pass/Exception]	[Failure tickets, resolution evidence]
Restoration testing performed	[Pass/Exception]	[Restore test report]
Disaster recovery exercise completed	[Pass/Exception]	[Exercise report, lessons learned]

Finding

Field	Detail
Finding ID	SOC2-F-[009]
Severity	[Low/Medium/High/Observation]
Condition	[Describe result.]
Criteria	Availability and recovery controls should support the organisation's service commitments and recovery objectives.

Field	Detail
Cause	[Cause.]
Effect / Risk	[Risk.]
Evidence	[Evidence.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Status]

10. Vendor and Subprocessor Management

Control Expectations

Vendors and subprocessors that support the in-scope service should be assessed, approved, monitored, and contractually bound to appropriate security, confidentiality, availability, privacy, and compliance obligations.

Procedures Performed

- Reviewed vendor inventory and risk classifications.
- Tested due diligence evidence for sampled vendors.
- Reviewed contracts and security commitments for key vendors.
- Inspected annual reassessment evidence.
- Confirmed tracking of subprocessors and customer notification processes where applicable.
- Reviewed vendor assurance reports and management review of exceptions.

Results

Test Area	Result	Evidence Reviewed
Vendor inventory maintained	[Pass/Exception]	[Vendor register]
Vendors risk-rated	[Pass/Exception]	[Risk assessment records]
Due diligence completed before onboarding	[Pass/Exception]	[Questionnaires, assurance reports]
Annual reassessments completed	[Pass/Exception]	[Review records]
Contractual protections in place	[Pass/Exception]	[Contracts, data processing terms]

Finding

Field	Detail
Finding ID	SOC2-F-[010]
Severity	[Low/Medium/High/Observation]
Condition	[Example: Annual reassessment evidence was incomplete for one medium-risk vendor.]
Criteria	Vendors supporting the service should be reviewed at onboarding and periodically thereafter based on risk.
Cause	[Example: Vendor reassessment ownership was not updated following team reorganisation.]
Effect / Risk	[Example: Incomplete reassessment may reduce visibility into changes in vendor risk.]
Evidence	[Vendor register, review record, contract file]

Field	Detail
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Open/In Progress/Closed]

11. Confidentiality and Data Protection

Control Expectations

Confidential information should be identified, protected, transmitted securely, retained only as needed, and disposed of securely when no longer required.

Procedures Performed

- Reviewed data classification and handling procedures.
- Inspected encryption configuration for data in transit and at rest.
- Reviewed access controls for confidential customer data.
- Evaluated data retention and deletion practices.
- Reviewed secure transfer and sharing mechanisms.
- Confirmed confidentiality obligations for personnel and vendors.

Results

Test Area	Result	Evidence Reviewed
Data classification guidance maintained	[Pass/Exception]	[Data handling policy]
Encryption applied where required	[Pass/Exception]	[Cloud configuration, TLS settings]
Confidential data access restricted	[Pass/Exception]	[Access listings]
Retention requirements documented	[Pass/Exception]	[Retention schedule]
Secure disposal performed where applicable	[Pass/Exception]	[Deletion records, disposal certificates]

Finding

Field	Detail
Finding ID	SOC2-F-[011]
Severity	[Low/Medium/High/Observation]
Condition	[Describe result.]
Criteria	Confidential information should be protected against unauthorised access, disclosure, alteration, and retention beyond business need.
Cause	[Cause.]
Effect / Risk	[Risk.]
Evidence	[Evidence.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Status]

12. Privacy Operations

Control Expectations

Where personal information is processed as part of the in-scope service, privacy practices should align with published notices, customer agreements, consent requirements, data subject request processes, retention rules, and subprocessor commitments.

Procedures Performed

- Reviewed privacy notice and customer-facing privacy commitments.
- Inspected data processing agreements and subprocessor disclosures.
- Tested privacy request handling records where applicable.
- Reviewed personal data retention and deletion procedures.
- Confirmed privacy impact review for relevant product or process changes.
- Reviewed breach notification decision records for incidents involving personal information.

Results

Test Area	Result	Evidence Reviewed
Privacy commitments documented and approved	[Pass/Exception]	[Privacy notice, customer terms]
Personal data inventory maintained	[Pass/Exception]	[Data map, processing register]
Privacy requests handled timely	[Pass/Exception]	[Request tickets]
Subprocessors disclosed and reviewed	[Pass/Exception]	[Subprocessor list, vendor files]
Privacy reviews performed for material changes	[Pass/Exception]	[Privacy review records]

Finding

Field	Detail
Finding ID	SOC2-F-[012]
Severity	[Low/Medium/High/Observation]
Condition	[Describe result.]
Criteria	Personal information should be processed in line with documented commitments and applicable customer obligations.
Cause	[Cause.]
Effect / Risk	[Risk.]
Evidence	[Evidence.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Status]

13. Human Resources and Personnel Security

Control Expectations

Personnel security controls should support trustworthy hiring, appropriate onboarding, security training, role changes, and timely offboarding.

Procedures Performed

- Reviewed background screening evidence for sampled personnel where permitted.
- Tested onboarding completion, policy acknowledgement, and training records.
- Reviewed role change process and access update evidence.
- Tested termination records against access removal logs.
- Reviewed confidentiality agreements and acceptable use acknowledgements.

Results

Test Area	Result	Evidence Reviewed
Background checks completed where required	[Pass/Exception]	[HR records, screening confirmations]
Confidentiality agreements completed	[Pass/Exception]	[Signed agreements]
New hire onboarding completed	[Pass/Exception]	[Onboarding checklist]
Role changes communicated to access owners	[Pass/Exception]	[HRIS records, tickets]
Offboarding completed timely	[Pass/Exception]	[Termination checklist, system logs]

Finding

Field	Detail
Finding ID	SOC2-F-[013]
Severity	[Low/Medium/High/Observation]
Condition	[Describe result.]
Criteria	Personnel lifecycle processes should ensure that individuals are suitable, trained, and granted access appropriate to their responsibilities.
Cause	[Cause.]
Effect / Risk	[Risk.]
Evidence	[Evidence.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Status]

14. Business Continuity and Resilience

Control Expectations

The organisation should maintain continuity and recovery arrangements that support continued delivery of the in-scope service during disruption.

Procedures Performed

- Reviewed business continuity and disaster recovery plans.

- Inspected evidence of plan testing or tabletop exercises.
- Reviewed recovery objectives and alignment with customer commitments.
- Evaluated lessons learned and remediation tracking.
- Confirmed communication procedures for major service disruptions.
- Reviewed dependencies on critical vendors and infrastructure providers.

Results

Test Area	Result	Evidence Reviewed
Continuity plans maintained	[Pass/Exception]	[Business continuity plan]
Recovery plans maintained	[Pass/Exception]	[Disaster recovery plan]
Exercise performed during reporting period	[Pass/Exception]	[Exercise records]
Lessons learned tracked	[Pass/Exception]	[Action plan]
Critical dependencies identified	[Pass/Exception]	[Dependency register]

Finding

Field	Detail
Finding ID	SOC2-F-[014]
Severity	[Low/Medium/High/Observation]
Condition	[Describe result.]
Criteria	Resilience arrangements should be documented, tested, and updated based on business and technical dependencies.
Cause	[Cause.]
Effect / Risk	[Risk.]
Evidence	[Evidence.]
Management Response	[Response.]
Remediation Owner	[Owner]
Target Completion Date	[Date]
Status	[Status]

Consolidated Findings Register

Finding ID	Area	Severity	Finding Summary	Root Cause	Owner	Target Date	Status
SOC2-F-[001]	Governance and Risk Management	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[002]	Security Policies and Awareness	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[003]	Logical Access Management	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[004]	Privileged Access Management	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[005]	Change Management	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[006]	Secure Development	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]

Finding ID	Area	Severity	Finding Summary	Root Cause	Owner	Target Date	Status
SOC2-F-[007]	Security Monitoring and Incident Response	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[008]	Vulnerability and Patch Management	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[009]	Availability, Backup, and Recovery	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[010]	Vendor and Subprocessor Management	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[011]	Confidentiality and Data Protection	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[012]	Privacy Operations	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[013]	Human Resources and Personnel Security	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]
SOC2-F-[014]	Business Continuity and Resilience	[Severity]	[Summary]	[Root cause]	[Owner]	[Date]	[Status]

Analysis

Overall Control Environment

The overall control environment demonstrates a structured approach to security, risk management, and operational assurance. Control ownership is generally defined, core security processes are documented, and evidence is retained across key operational systems.

The strongest areas observed were:

- Centralised authentication and access governance.
- Structured change management using workflow and source control evidence.
- Security monitoring with assigned response ownership.
- Backup and availability monitoring for critical components.
- Formal vendor review for key suppliers.
- Management visibility into security and compliance activities.

Areas requiring continued attention include:

- Ensuring access reviews are completed consistently and on schedule.
- Improving completeness of evidence for urgent or emergency changes.
- Strengthening vendor reassessment tracking.
- Formalising evidence retention expectations for operational controls.
- Maintaining current ownership for controls affected by organisational change.

- Ensuring privacy and data retention practices remain aligned with product growth and customer requirements.

Root Cause Themes

The following root cause themes were identified across findings and observations:

Theme	Description	Impact
Process Bypass During Urgent Activity	Some exceptions occurred when teams responded quickly to operational needs and updated evidence after the fact or not at all.	May reduce auditability and weaken control traceability.
Ownership Changes	Some control activities were affected by changes in team structure, role ownership, or vendor responsibility.	May result in missed reviews or incomplete follow-up.
Evidence Fragmentation	Evidence is stored across multiple systems, including tickets, repositories, dashboards, documents, and spreadsheets.	May increase effort and risk of incomplete evidence collection.
Manual Follow-Up	Certain controls depend on manual reminders or manager follow-up.	May lead to inconsistent execution during busy periods.
Scaling Pressure	Growth in systems, personnel, vendors, and customer commitments increases the volume of control activity.	Requires increased automation, reporting, and control monitoring.

Risk Assessment of Findings

Severity	Number of Findings	Risk Implication
High	[Number]	May materially affect assurance if not remediated promptly.
Medium	[Number]	Requires management attention and corrective action within agreed timelines.
Low	[Number]	Does not materially impair the control environment but should be addressed.
Observation	[Number]	Improvement opportunity without identified control failure.

Impact on Service Commitments

Based on the evidence reviewed, identified exceptions [did / did not] indicate a material failure to meet customer-facing service commitments during the reporting period.

Commitment Area	Impact Assessment
Security Commitments	[No material impact / Potential impact / Material impact]
Availability Commitments	[No material impact / Potential impact / Material impact]
Confidentiality Commitments	[No material impact / Potential impact / Material impact]
Privacy Commitments	[No material impact / Potential impact / Material impact]
Processing Commitments	[No material impact / Potential impact / Material impact]

Compensating Controls

Where exceptions were identified, the following compensating controls were considered:

Exception Area	Compensating Control	Assessment
Access approval exception	Periodic access review, multi-factor authentication, logging, manager validation	[Adequate / Partially adequate / Not adequate]
Change approval exception	Peer review, deployment logs, automated testing, production monitoring	[Adequate / Partially adequate / Not adequate]
Vendor reassessment delay	Existing contract terms, prior due diligence, continuous monitoring, vendor assurance report	[Adequate / Partially adequate / Not adequate]

Exception Area	Compensating Control	Assessment
Asset inventory completeness	Endpoint management agent, network discovery, procurement records	[Adequate / Partially adequate / Not adequate]

Prior Period Comparison

Area	Prior Period Result	Current Period Result	Trend
Access Management	[Effective / Exceptions]	[Effective / Exceptions]	[Improved / Stable / Declined]
Change Management	[Effective / Exceptions]	[Effective / Exceptions]	[Improved / Stable / Declined]
Incident Response	[Effective / Exceptions]	[Effective / Exceptions]	[Improved / Stable / Declined]
Vendor Management	[Effective / Exceptions]	[Effective / Exceptions]	[Improved / Stable / Declined]
Availability and Recovery	[Effective / Exceptions]	[Effective / Exceptions]	[Improved / Stable / Declined]
Privacy Operations	[Effective / Exceptions]	[Effective / Exceptions]	[Improved / Stable / Declined]

Management Readiness Assessment

Readiness Area	Status	Comments
Control design documentation	[Ready / Needs work]	[Comments]
Evidence availability	[Ready / Needs work]	[Comments]
Control owner awareness	[Ready / Needs work]	[Comments]
Remediation tracking	[Ready / Needs work]	[Comments]
Customer assurance readiness	[Ready / Needs work]	[Comments]
External audit readiness	[Ready / Needs work]	[Comments]

Recommendations & Actions

Management Action Plan

Action ID	Related Finding	Action	Owner	Priority	Target Date	Success Criteria	Status
SOC2-A-[001]	SOC2-F-[001]	[Define or update management review cadence and ensure action tracking is reviewed monthly.]	[Owner]	[High/Medium/Low]	[Date]	Meeting records show risks, findings, and actions reviewed at defined frequency.	[Open/In Progress/Closed]
SOC2-A-[002]	SOC2-F-[003]	[Implement automated alerts for overdue access reviews and require evidence of reviewer sign-off.]	[Owner]	[High/Medium/Low]	[Date]	Access reviews completed by due date with documented disposition of exceptions.	[Open/In Progress/Closed]
SOC2-A-[003]	SOC2-F-[005]	[Update emergency change workflow to require retrospective approval and closure within defined timeframe.]	[Owner]	[High/Medium/Low]	[Date]	Emergency change tickets contain implementation, approval, testing, and review evidence.	[Open/In Progress/Closed]
SOC2-A-[004]	SOC2-F-[010]	[Assign vendor reassessment owners and configure recurring review reminders.]	[Owner]	[High/Medium/Low]	[Date]	Vendor reviews completed based on risk classification and tracked centrally.	[Open/In Progress/Closed]

Action ID	Related Finding	Action	Owner	Priority	Target Date	Success Criteria	Status
SOC2-A-[005]	SOC2-F-[008]	[Enhance vulnerability reporting dashboard to show ageing, ownership, and exception status.]	[Owner]	[High/Medium/Low]	[Date]	Vulnerability remediation status is visible and reviewed by management.	[Open/In Progress/Closed]
SOC2-A-[006]	SOC2-F-[011]	[Validate retention and deletion workflows for customer confidential data.]	[Owner]	[High/Medium/Low]	[Date]	Retention and deletion evidence is available for sampled data types.	[Open/In Progress/Closed]

Recommended Control Enhancements

The following enhancements are recommended to improve consistency, scalability, and audit readiness:

• Automate recurring control reminders

- Configure automated notifications for access reviews, vendor reassessments, policy reviews, continuity testing, and training deadlines.
- Maintain escalation rules for overdue control activities.

• Centralise evidence management

- Establish a SOC 2 evidence repository with defined naming standards, ownership, and retention periods.
- Link evidence to control activities, reporting periods, and control owners.

• Strengthen control owner accountability

- Maintain a control owner register with primary and backup owners.
- Require quarterly attestation from control owners confirming operation and evidence availability.

• Improve exception documentation

- Require all control exceptions to include root cause, risk assessment, compensating controls, owner, target date, and closure evidence.
- Review open exceptions in management meetings until closure.

• Enhance privileged access governance

- Implement just-in-time access where feasible.
- Reduce standing administrator access.
- Monitor administrative actions for unusual activity.

• Improve change traceability

- Ensure production deployments are linked to approved tickets, pull requests, test results, and release notes.
- Require post-implementation review for emergency and high-risk changes.

• Expand security monitoring coverage

- Review logging coverage for all critical infrastructure, applications, identity systems, and administrative actions.
- Define minimum log retention and alert response expectations.
- **Mature vendor monitoring**
- Risk-rate all vendors supporting the service.
- Track assurance report review results and vendor exceptions.
- Document management's assessment of vendor control gaps.
- **Validate resilience assumptions**
- Perform periodic recovery testing for critical systems.
- Document actual recovery times achieved during testing.
- Update recovery procedures based on exercise lessons learned.
- **Align privacy operations with product changes**
- Include privacy review in product and engineering change processes.
- Maintain current records of personal data processing, subprocessors, and retention obligations.

Remediation Governance

Remediation will be governed as follows:

Activity	Frequency	Responsible Party	Output
Findings status review	Bi-weekly until all high and medium findings are closed	[GRC Lead]	Updated action tracker
Executive remediation review	Monthly	[Executive Sponsor]	Management status update
Evidence validation	Upon action closure	[Compliance / Internal Audit]	Closure confirmation
Risk acceptance review	As needed	[Risk Owner]	Approved risk acceptance record
Customer-impact assessment	As needed	[Legal / Customer Success / Security]	Communication decision record
External audit readiness review	Prior to auditor fieldwork	[Compliance Owner]	Readiness assessment

Closure Criteria

A remediation action may be closed only when:

- The corrective action has been implemented.
- Evidence demonstrates the corrected process or control is operating as intended.
- The control owner confirms ongoing responsibility.
- Any related procedure, workflow, or system configuration has been updated.
- The GRC or compliance function validates the closure evidence.
- Residual risk is accepted by the appropriate risk owner where full remediation is not feasible.

Target Remediation Timeline

Severity	Target Remediation Timeline
High	Immediate containment and remediation plan within [Number] business days; closure targeted within [Number] days unless formally risk-accepted
Medium	Remediation targeted within [Number] days
Low	Remediation targeted within [Number] days or by the next control cycle
Observation	Management to evaluate and address based on risk, cost, and operational benefit

Distribution & Confidentiality

Distribution

This report is confidential and intended only for authorised recipients with a legitimate business need.

Approved recipients may include:

Recipient Group	Access Purpose
Executive Management	Oversight of control effectiveness, risk, and remediation
Board or Audit Committee	Governance oversight and risk awareness
Security and Engineering Leadership	Control ownership and remediation
Compliance and GRC Team	Audit readiness and evidence management
Internal Audit	Independent review and validation
External Service Auditor	SOC 2 audit planning and testing support
Legal and Privacy Teams	Contractual, privacy, and customer assurance support
Customer Assurance Team	Responding to authorised customer requests
Customers and Prospects	Only where approved and subject to confidentiality restrictions

Confidentiality Requirements

This report contains sensitive information about [Organisation Name]’s systems, controls, risks, vendors, security processes, and operational practices. Unauthorised disclosure could increase security, commercial, legal, or reputational risk.

Recipients must:

- Use the report only for the authorised purpose.
- Not copy, forward, publish, or distribute the report without written approval from [Authorised Approver].
- Store the report securely using approved systems.
- Protect the report from unauthorised access.
- Return or destroy the report upon request, unless retention is required by contract or law.
- Not extract technical details for use outside the approved assurance process.

Customer Release Conditions

Where this report, or a customer-facing version of this report, is shared externally:

- Release must be approved by [Legal / Compliance / Executive Sponsor].
- A non-disclosure agreement or equivalent confidentiality obligation must be in place.

- The recipient must be authorised and verified.
- Sensitive details may be redacted where necessary.
- The report must be watermarked or otherwise marked for restricted use where feasible.
- Distribution must be logged by [Customer Assurance / Compliance Team].

Retention

Record Type	Retention Period	Repository	Owner
Final SOC 2 Type 2 Report	[Retention Period]	[Repository]	[Compliance Owner]
Evidence Records	[Retention Period]	[Evidence Repository]	[Control Owners / GRC]
Findings and Remediation Tracker	[Retention Period]	[GRC Tool / Repository]	[GRC Lead]
Management Approvals	[Retention Period]	[Repository]	[Compliance Owner]
External Distribution Log	[Retention Period]	[CRM / GRC Tool / Repository]	[Customer Assurance Owner]

Approval

Role	Name	Approval Date	Signature / Approval Record
Report Owner	[Name]	[Date]	[Approval reference]
Security Leader	[Name]	[Date]	[Approval reference]
Compliance Leader	[Name]	[Date]	[Approval reference]
Executive Sponsor	[Name]	[Date]	[Approval reference]